# CCSA104 LAB: Managing Security Policies

## Lab Report

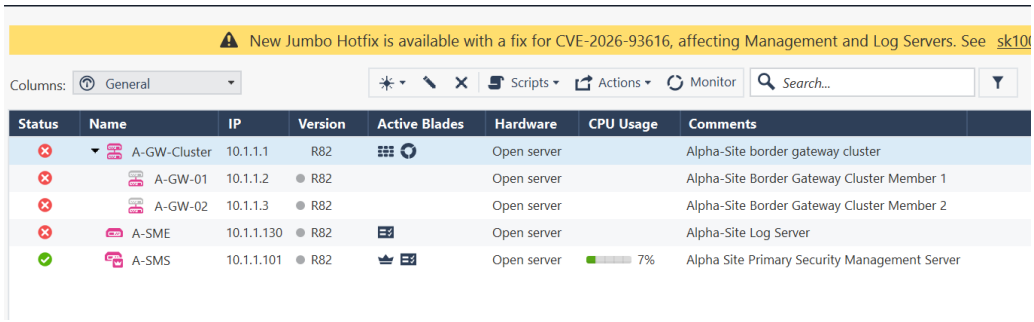
| | |
|---|---|
| **Student name:** | Jegede Samuel Aduragbemi |
| **Date completed:** | 7 November 2026 |
| **Student ID:** | c11.ccsa2617113@icdfa.edu.ng |
| **Lab:** | CCSA104 Lab: Managing Security Policies |

## Assistance Disclosure

I used an AI assistant to explain concepts, help me plan the steps and review the wording of my answers. I carried out all lab steps and took all screenshots myself in my own lab environment.

## Environment limitation

My host computer has 16 GB of RAM and the A-SMS virtual machine already uses 8 GB, so I could not power on a Security Gateway or test hosts. In Gateways & Servers, A-GW-Cluster, A-GW-01, A-GW-02 and the log server A-SME showed a red status; only A-SMS was running (see screenshot below). I therefore completed and published all steps that need only the Security Management Server: creating objects, building the rulebase, sections and Hide NAT. Each Install Policy attempt in Task 7 failed on the gateways, so I could not run the traffic test or read gateway logs




*Gateways & Servers status: gateways and log server not running*

**Note on missing tasks:** The Student copy of the assignment brief that I received does not contain Task 3, Task 5 or the test table (T1–T4). The brief's final rulebase includes rule 4 "Internal to DMZ", which is added in Task 5, so I could not build that rule. Test T4 in Task 7 was also not defined, so I could not run it, and with the gateways not running no traffic test was possible anyway

# Part A: Practical Tasks

### Task 1: Explore the default policy

Policy package in use: Standard

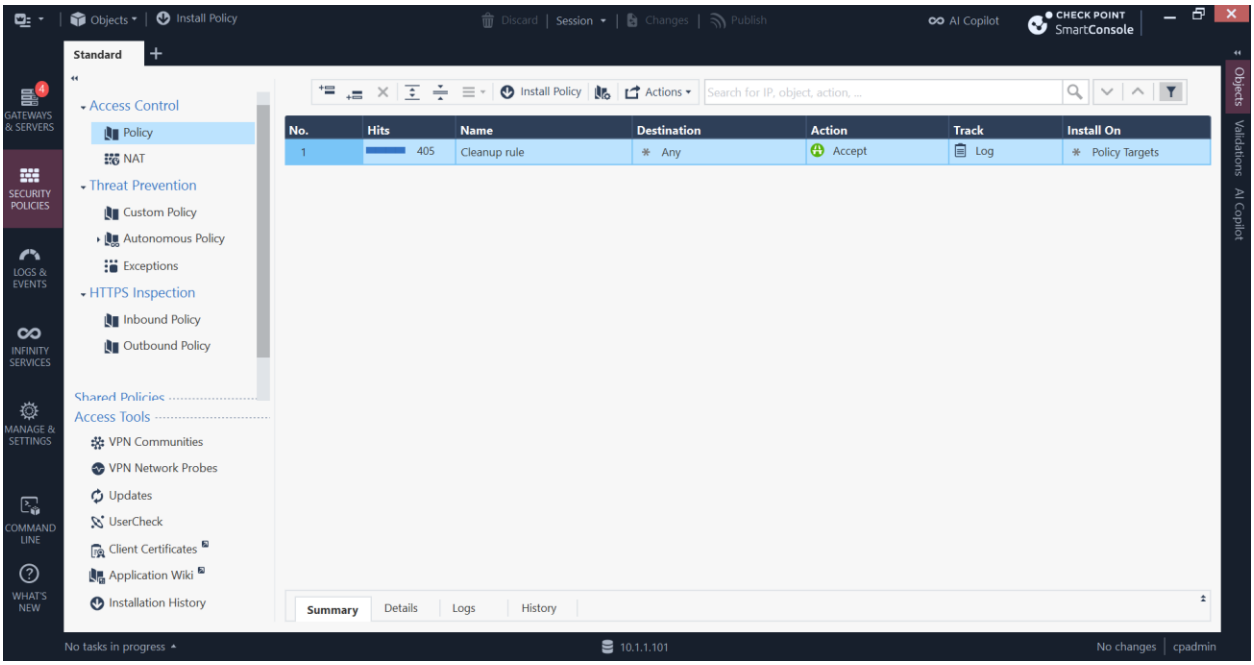
**Default Cleanup rule values**

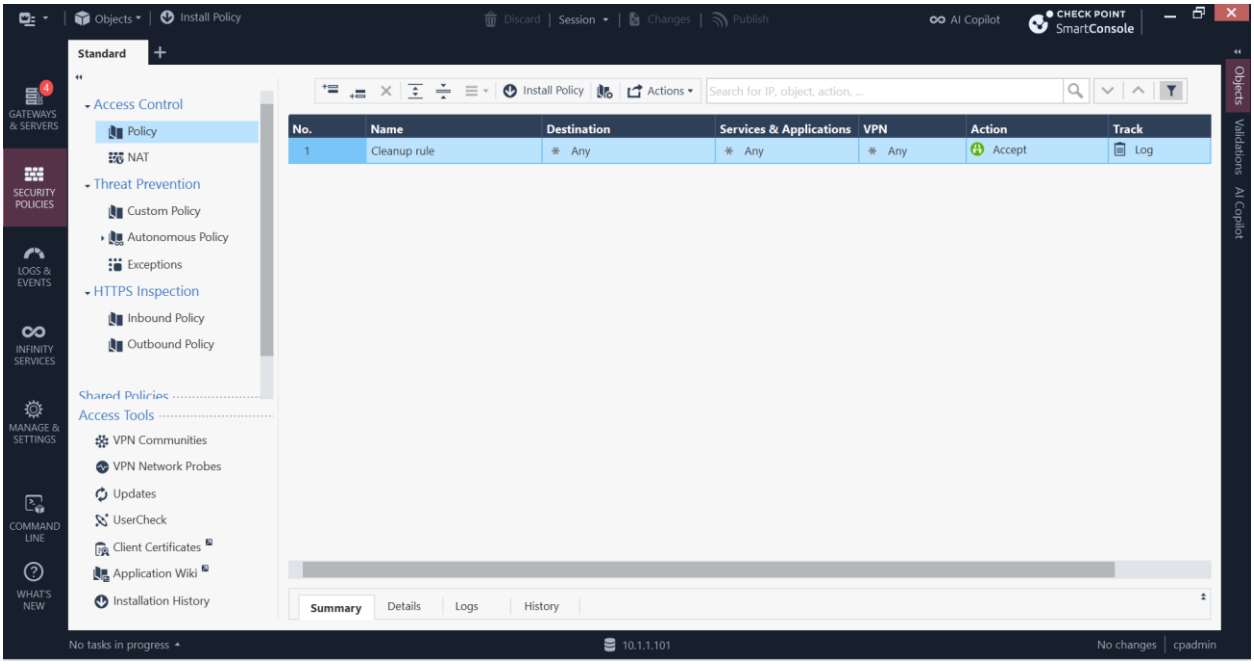
| Field | Value I recorded |
|---|---|
| **Name** | Cleanup rule |
| **Source** | Any |
| **Destination** | Any |
| **Services & Applications** | Any |
| **Action** | Accept |
| **Track** | Log |
| **Install On** | Policy Targets |

Columns: I right-clicked a column header and showed the Hits, Track and Install On columns, hid two column (Services & Application, VPN) and showed it again.

**Global Properties (Applications menu):** three categories of settings I saw: FireWall, NAT and Authentication.

**Manage policies and layers:** the policy packages that exist: Alpha-Standard and Standard




## Task 1 - Rulebase

## Task 2: Build the Access Control rulebase

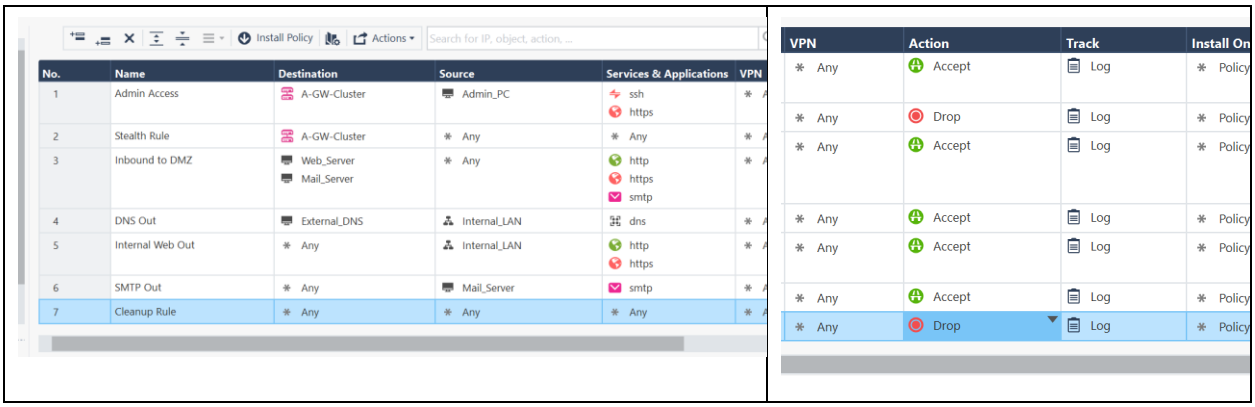
**Objects created**

| Object | Type | Value I used | Where the value came from |
|---|---|---|---|
| **Internal_LAN** | Network | 192.168.11.0 / 255.255.255.0 | Copied from the lab's existing A-INT-NET (Alpha-Site Internal Network) |
| **DMZ_Net** | Network | 192.168.12.0 / 255.255.255.0 | Copied from the lab's existing A-DMZ-NET (Alpha-Site DMZ) |
| **Admin_PC** | Host | 10.1.1.201 | My admin machine, A-GUI, in the lab topology |
| **Web_Server** | Host | 192.168.12.150 | The lab's existing Student-Web-Server ("Internal Web Server for Lab") in the DMZ |
| **Mail_Server** | Host | 192.168.12.25 | A placeholder address I chose inside DMZ_Net, because the lab has no mail server |
| **External_DNS** | Host | 168.63.129.16 | The lab's existing Azure-External DNS object |

**Final rulebase**

| No. | Name | Source | Destination | Services & Applications | Action | Track |
|---|---|---|---|---|---|---|
| **1** | Admin Access | Admin_PC | A-GW-Cluster | ssh, https | Accept | Log |
| **2** | Stealth Rule | Any | A-GW-Cluster | Any | Drop | Log |
| **3** | Inbound to DMZ | Any | Web_Server, Mail_Server | http, https, smtp | Accept | Log |
| 4 | DNS Out | Internal_LAN | External_DNS | dns (UDP and TCP) | Accept | Log |
| 5 | Internal Web Out | Internal_LAN | Any | http, https | Accept | Log |
| 6 | SMTP Out | Mail_Server | Any | smtp | Accept | Log |
| 7 | Cleanup Rule | Any | Any | Any | Drop | Log |

**Cleanup rule:** The Cleanup rule already existed, so I did not recreate it. I changed its Action from Accept to Drop and kept Track as Log. I also renamed it to “Cleanup Rule”. It stays as the last rule, so anything not explicitly allowed above is dropped (Positive Control model)

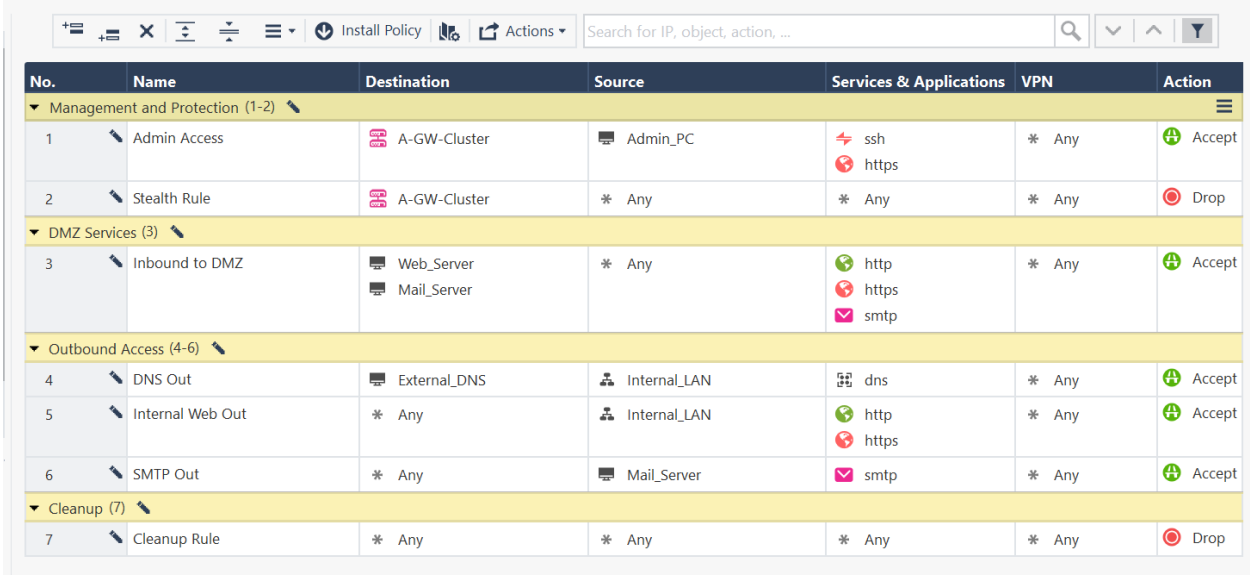



**Task 2 - Rulebase**

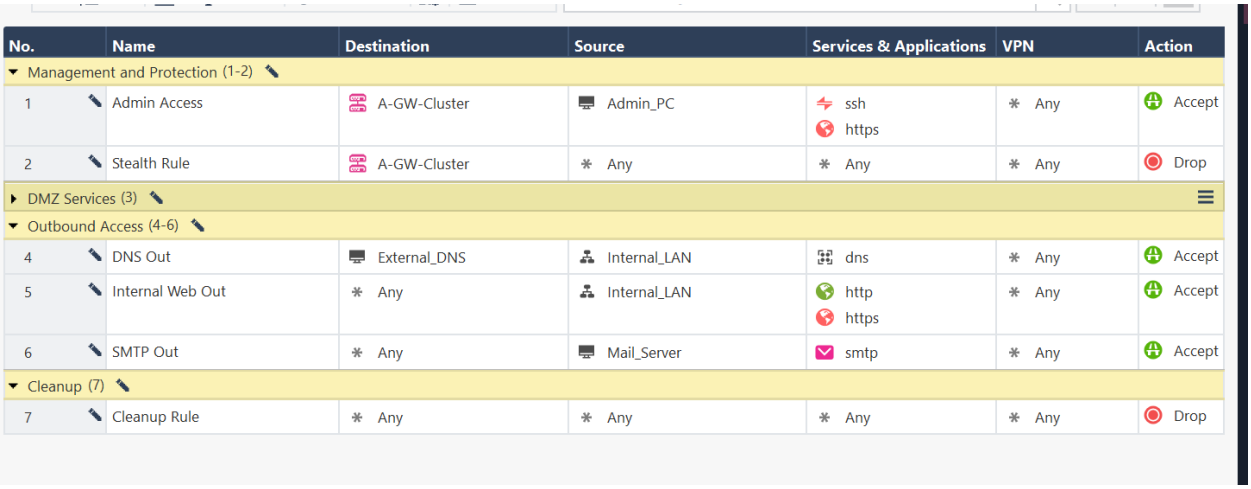
## Task 4: Organise the rulebase with sections

| Section title | Contains |
|---|---|
| **Management and Protection** | Rules 1 and 2 |
| **DMZ Services** | Rules 3 |
| **Outbound Access** | Rules 4, 5, and 6 |
| **Cleanup** | Rule 7 |

I created the four sections with New Section Title (Above), collapsed and expanded DMZ Services and edited the Cleanup section title and changed it back




**Task 4 - Sections expanded**



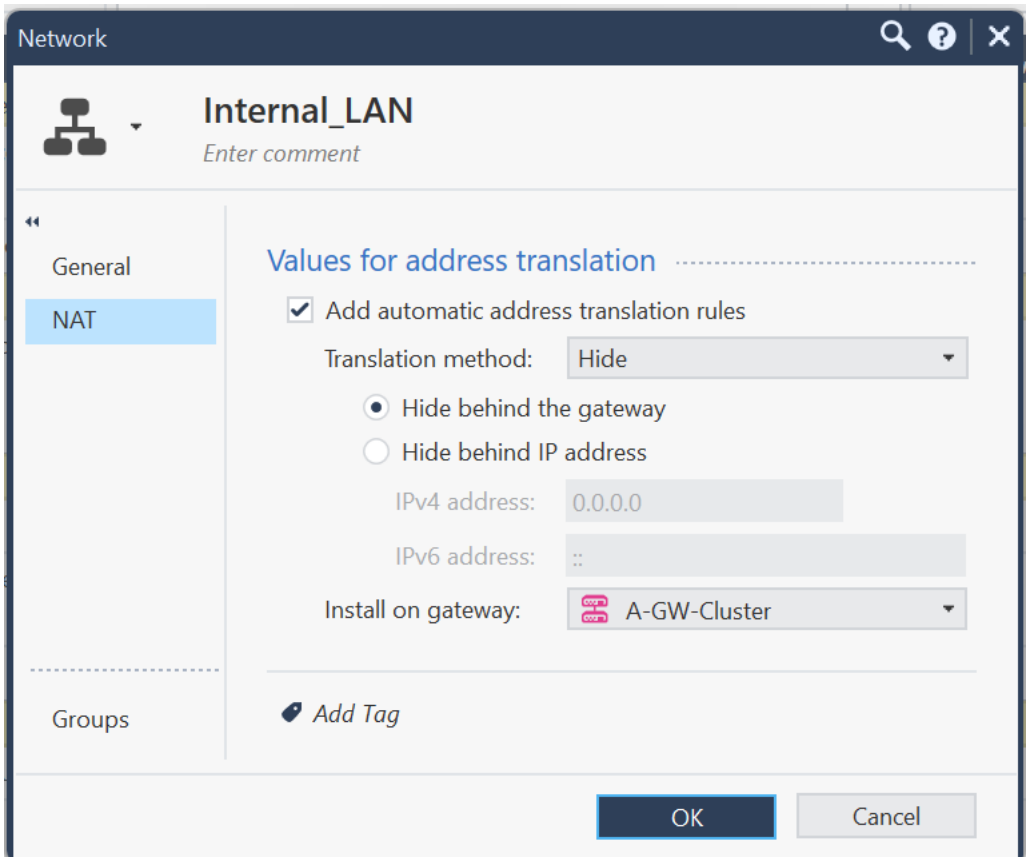
| No. | Name | Destination | Source | Services & Applications | VPN | Action |
|---|---|---|---|---|---|---|
| Management and Protection (1-2) | | | | | | |
| 1 | Admin Access | A-GW-Cluster | Admin_PC | ssh<br>https | Any | Accept |
| 2 | Stealth Rule | A-GW-Cluster | Any | Any | Any | Drop |
| DMZ Services (3) | | | | | | |
| Outbound Access (4-6) | | | | | | |
| 4 | DNS Out | External_DNS | Internal_LAN | dns | Any | Accept |
| 5 | Internal Web Out | Any | Internal_LAN | http<br>https | Any | Accept |
| 6 | SMTP Out | Any | Mail_Server | smtp | Any | Accept |
| Cleanup (7) | | | | | | |
| 7 | Cleanup Rule | Any | Any | Any | Any | Drop |

**Task 4 - One section collapsed**

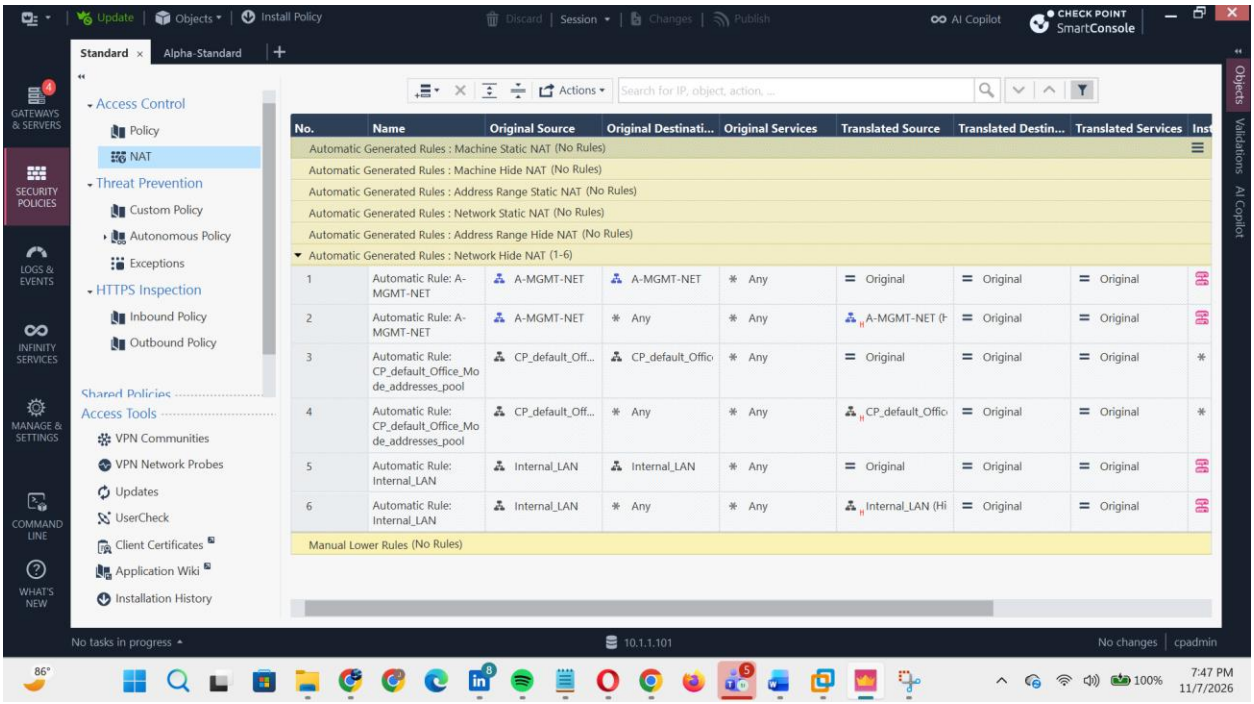
Sections are visual divisions only: they do not affect the order in which rules are enforced, and they are not sent to the Security Gateway as rules (Slide 28).

## Task 6: Configure Hide NAT

I opened the Internal_LAN object, went to its NAT page, enabled automatic address translation rules, chose Hide and hid the network behind the gateway. I published the change and found the automatic rule in the NAT rulebase.




**Task 6 - Internal_LAN NAT settings**




**Task 6 - NAT rulebase**

## Explanation

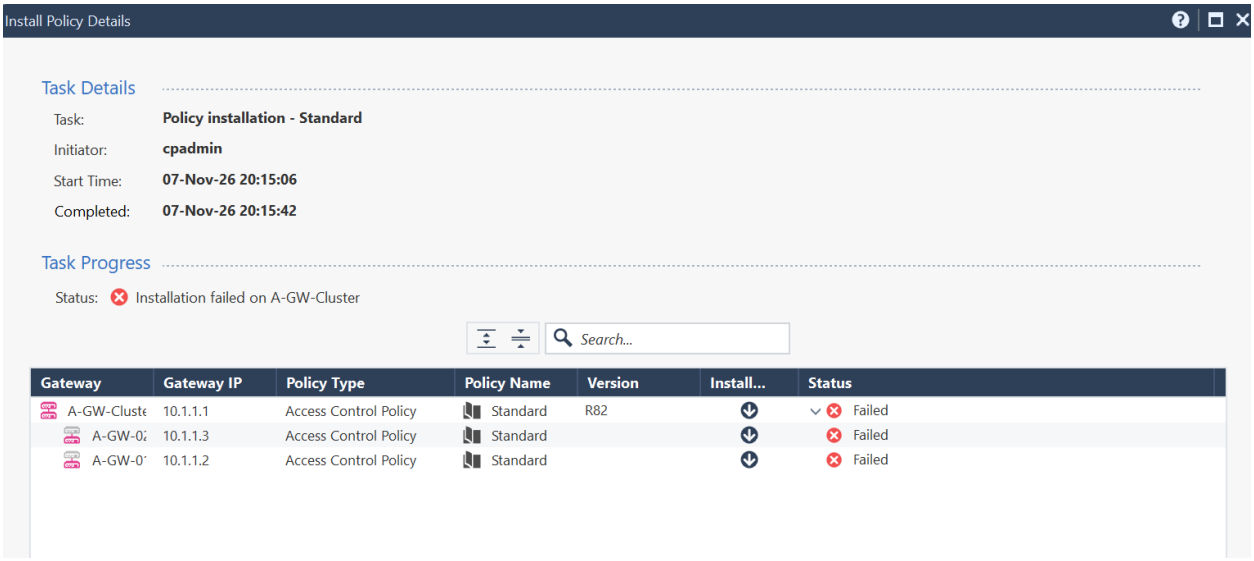
Why it is an automatic rule: the Security Management Server created it by itself from the NAT settings I entered in the Internal_LAN object. A manual rule is one the administrator writes in the NAT rulebase, for example for port forwarding or conditional translation (Slide 53).

Many-to-one: Hide NAT translates many internal addresses to one address, so all hosts in Internal_LAN appear on the Internet with a single address, which conserves public addresses and hides the internal network (Slide 55).

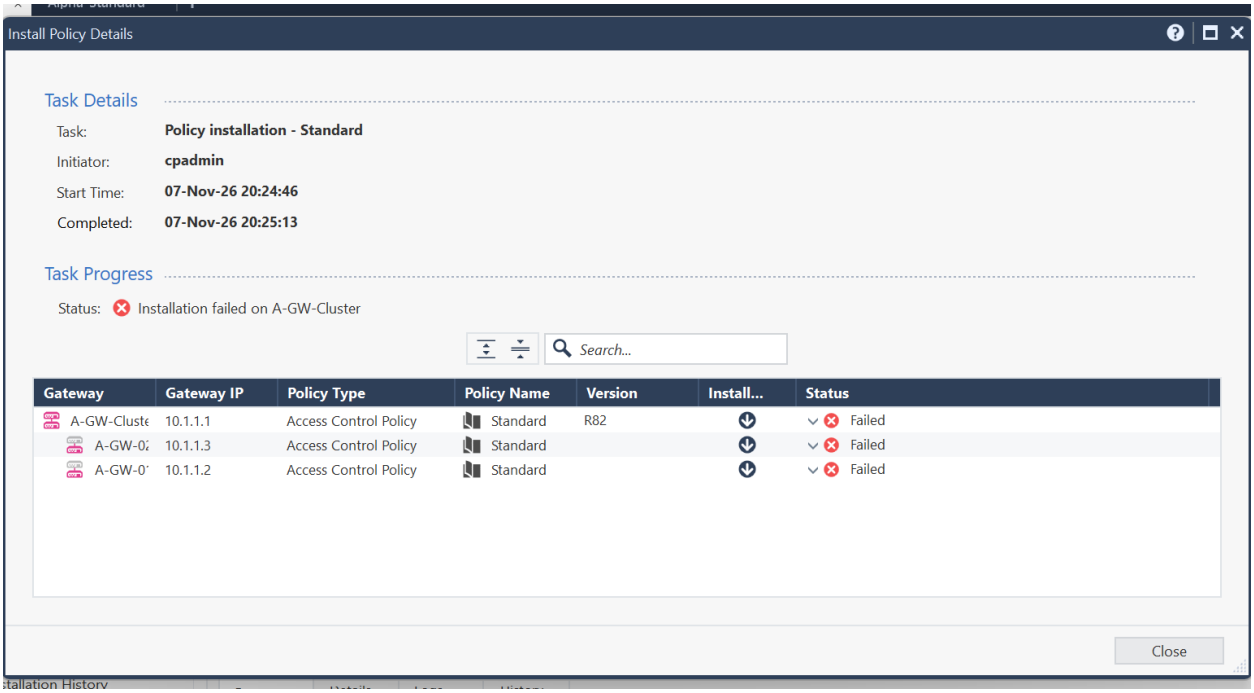
Source port: because many hosts share one address, the gateway also changes the source port of each connection to a unique value. This lets it tell the connections apart and send each reply back to the correct internal computer.

## Task 7: Rule order experiment and Installation History

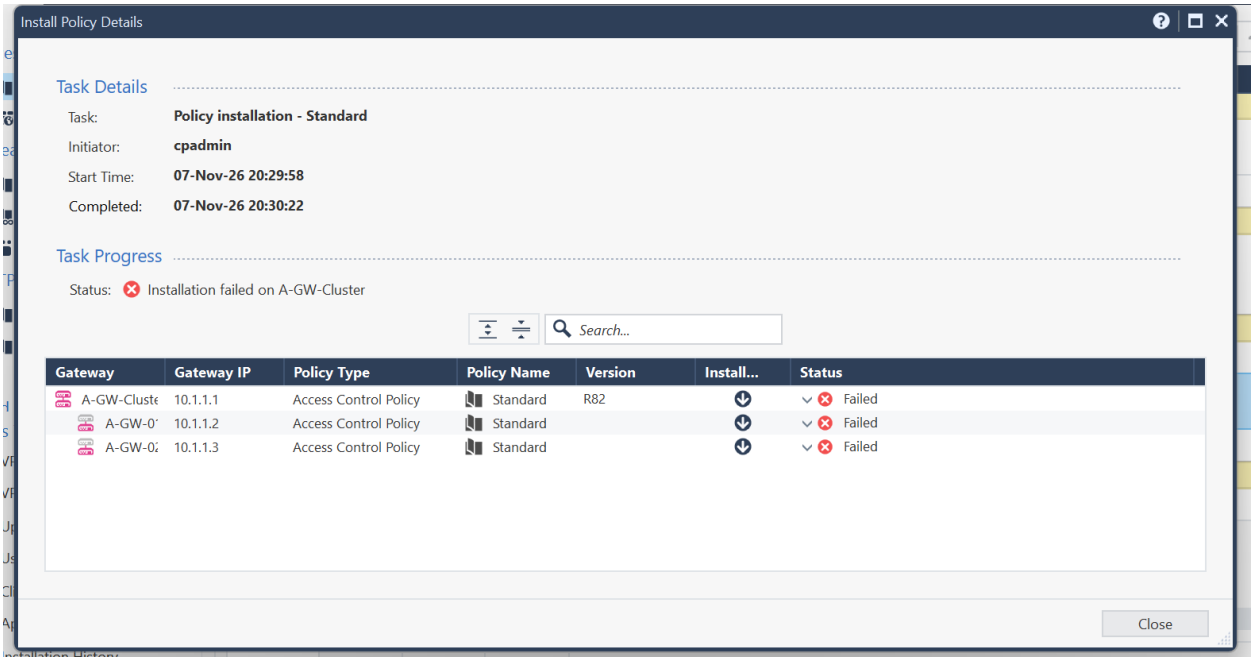
| Step | What I did | Result |
|---|---|---|
| **1. TEMP Block Internal above Internal Web Out** | Added the rule (Source Internal_LAN, Destination Any, Services Any, Action Drop, Track Log) above Internal Web Out, published, and tried Install Policy. | Install failed on A-GW-Cluster, A-GW-01 and A-GW-02 (07-Nov-26 20:15:06 to 20:15:42). The gateways were not running, so no traffic test (T4) or log was possible. |
| **2. Moved it below Internal Web Out** | Moved the rule below Internal Web Out, published, and tried Install Policy again. | Failed again (20:24:46 to 20:25:13). No log to read. |
| **3. Deleted the temporary rule** | Deleted TEMP Block Internal, published, and tried Install Policy again. | Failed again (20:29:58 to 20:30:22) |
| **4. Installation History** | Opened Security Policies > Access Tools > Installation History and looked at the list | It lists only two earlier installs of Alpha-Standard (12-Apr-26). None of my attempts appear, because none succeeded |



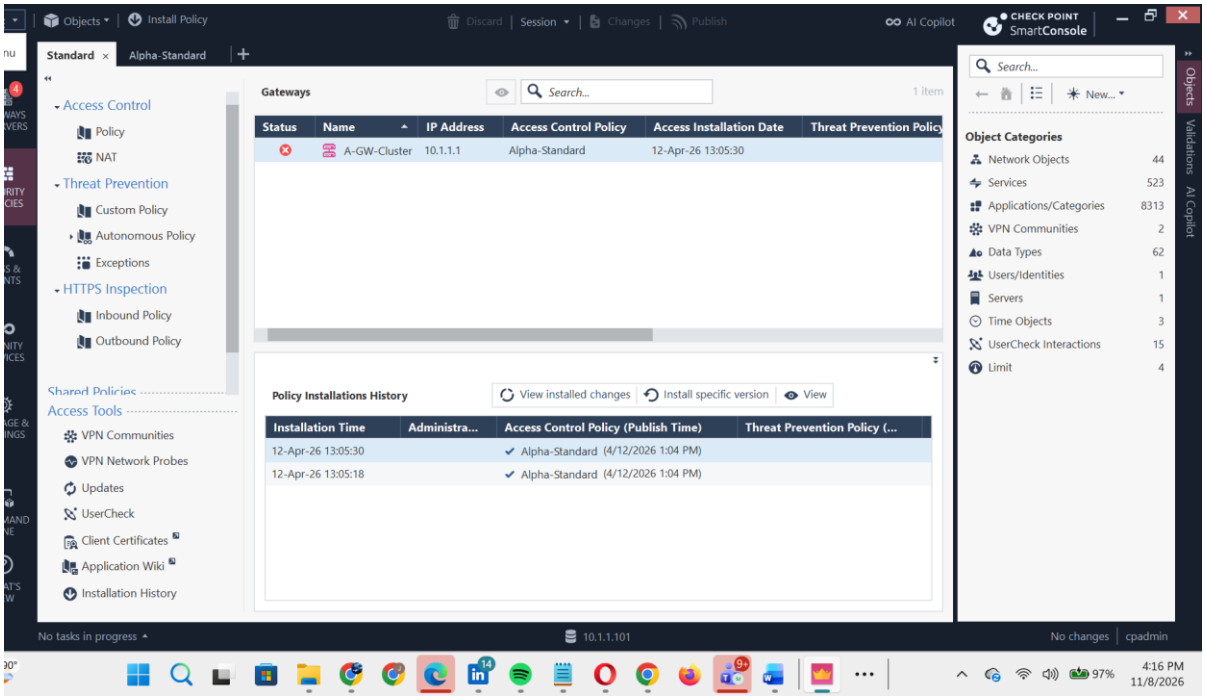

**Task 7 - Install attempt, step 1 (rule above)**




**Task 7 - Install attempt, step 2 (rule below)**




**Task 7 - Install attempt, step 3 (rule deleted)**




*Task 7 - Installation history*

Why specific rules belong above general rules: the gateway checks rules from the top down and applies the first rule that matches. If a general rule such as TEMP Block Internal (Internal_LAN to Any) sits above a specific rule such as Internal Web Out, it matches first and the specific rule is never reached. Putting specific rules above general ones lets the exceptions work while the general rules catch everything else (Slides 27 and 41).

Because the gateways were not running I could not confirm this in the logs, so this explanation is based on how rule matching works in the course slides (Slides 27 and 41).

## Part B: Theory Questions

Section B1: Multiple choice

| Question | Answer | Reason |
|---|---|---|
| **Q1** | B | Created in SmartConsole, stored on the Security Management Server, enforced by Security Gateways (Slide 4) |
| **Q2** | A | Positive Control Model (whitelist): it allows approved traffic and blocks everything else (Slide 6) |
| **Q3** | C | As early as possible, typically immediately after the Management rules (Slides 17 and 41) |
| **Q4** | D | Sections are visual divisions only and do not affect enforcement order (Slide 28). |
| **Q5** | B | Many-to-one: many internal addresses are hidden behind one address (Slide 55) |

### Section B2: Short answers

#### Q6. Explicit rules, Implied rules and the Implicit Cleanup Action

Explicit rules are created by the administrator and appear in the rulebase, allowing or blocking traffic based on criteria such as source, destination and service. Implied rules are created in Global Properties on the Security Management Server, are not visible in the rulebase, and can be placed first, last or before the last explicit rule (Slide 19). The Implicit Cleanup Action is not a rule but a Security Gateway behaviour for connections that no rule matched, and its options are Drop or Accept (Slide 20).

#### Q7. Why rule order matters

Rules are matched from the top down, and the first rule that matches a connection is the one applied, so specific rules must sit above general ones (Slides 27 and 41). In my rulebase, Admin Access (rule 1) is above the Stealth Rule (rule 2): if the Stealth Rule came first, it would drop administrator connections to the gateway before Admin Access could allow them.

#### Q8. Saving vs publishing

Saving is not the same as publishing: changes made during a SmartConsole session create a draft of the edited policy on the Security Management Server, and they only become part of the shared database when they are published (Slide 43). Unpublished session changes are not included when a policy is installed (Slide 39). Many organisations amend the policy regularly but publish only during a change window, so that changes reach the live gateways at an approved, controlled time.

**Q9. Global Properties vs Policy Packages**

Global Properties are enforced by all Security Gateways managed by the Security Management Server and cover settings for products such as Firewall, NAT, VPN and Logging and Alerts. For example, the Implied rules are configured there (Slides 19 and 35 to 37). They are opened from the Applications menu > Global Properties. Policy Packages are logical groupings of one or more policy types, such as Access Control, QoS, Desktop Security and Threat Prevention, which let different combinations of policies be installed on different gateways. They are managed from the Applications menu > Manage policies and layers (Slide 38).

**Q10. Security Zones**

The four predefined zones are InternalZone, ExternalZone, DMZZone and WirelessZone (Slide 29). A gateway interface can belong to only one Security Zone, but interfaces to different networks can be in the same zone (Slide 42). A benefit of zone-based rules is that they simplify rulebase creation and management, because one rule can cover every interface in a zone.

**Section B3: Scenario questions**

**Q11. Accept-Any rule above the Stealth rule**

First, a rule with Source Any, Destination Any, Services Any and Action Accept placed above the Stealth rule matches everything first, so the Stealth rule and every rule below it (including the Cleanup rule) can never match, and the gateway itself becomes reachable from anywhere. Second, it breaks the Positive Control Model, because instead of allowing only what is needed and dropping the rest, it allows everything. To correct it, delete or disable the rule, or replace it with specific rules for the traffic that is really needed, placed below the Stealth rule. Only Management rules (for example administrator access to the gateway over SSH or HTTPS) are allowed above the Stealth rule, because connections that must reach the gateway directly have to be accepted before the Stealth rule drops traffic addressed to the gateway (Slides 17 and 41).

**Q12. Hide NAT and staff cannot reach the Internet**

(a) Two benefits of NAT are security, because internal IP addresses are hidden behind a public address, and IP address conservation, because many devices on a private network can share a single public IP address (Slide 47). It also lets private addresses be reused across different networks without conflicts.

(b) Three checks:

1. Check the NAT rulebase and the installation: confirm the automatic Hide NAT rule for Internal_LAN exists and that the changes were published and installed on the gateway. This

matters because unpublished changes are not installed (Slide 39), so without it no translation happens.

2. Check the Access Control rules and the logs: confirm that Internal Web Out and DNS Out accept the traffic and that no earlier rule (such as the Stealth rule or a Drop rule) matches it. This matters because NAT only changes addresses; it does not allow traffic, and the log shows which rule dropped the connection.

3. Check routing, interfaces and DNS: confirm the gateway has a working external interface and default route, that the Hide address does not overlap other networks (Slide 56), and that the External_DNS server is reachable. This matters because a translated packet still needs a path to the Internet and its reply needs a path back, and names must resolve.

**References**

1. CCSA104 Security Policy Management, course slides (Slides 4, 6, 17, 19, 20, 27, 28, 29, 35 to 39, 41 to 43, 47, 53, 55 and 56 cited).

2. CCSA104 Practical Assignment, Lab 4A companion.